Classification Analysis and Defense Strategies of Vulnerabilities in User Account and Access Control Mechanisms: A Comprehensive Review

Tyson Lamb
Department of Computer Science
Slippery Rock University
Slippery Rock, PA, USA
trl1009@sru.edu

Christopher Shuler
Department of Computer Science
Slippery Rock University
Slippery Rock, PA, USA
cjs1057@sru.edu

Naresh Adhikari
Department of Computer Science
Slippery Rock University
Slippery Rock, PA, USA
naresh.adhikari@sru.edu

***Abstract*—User account and access control mechanisms play an important role in protecting sensitive data and preventing unauthorized access in modern information systems. However, these systems still face a wide range of security vulnerabilities that can be exploited by attackers, leading to data breaches, privilege escalation, and overall system compromise. This paper examines and classifies common vulnerabilities related to user authentication, authorization, session management, and identity management systems. A structured literature review approach was used to examine recent academic research and cybersecurity reports in order to identify patterns in vulnerabilities and evaluate different defense strategies. The results indicate that authentication weaknesses and broken access control are among the most common and serious issues, while solutions such as multi-factor authentication, least privilege models, and zero trust architecture are some of the most effective defenses. Even with these protections, gaps still exist due to inconsistent implementation and user-related factors like weak password practices. Overall, this paper highlights the need for layered security approaches and continuous improvements in access control systems to better reduce security risks.**

Keywords—access control, authentication, authorization, cybersecurity vulnerabilities, identity management, multi-factor authentication

I. Introduction

User account and access control systems are very important for keeping data secure and making sure only the right users can access certain parts of a system. As more businesses and organizations rely on web applications, cloud platforms, and online services, protecting things like logins and user permissions has become a bigger priority. If access control is not set up correctly, it can lead to serious problems like unauthorized access, data breaches, and even full system compromise. According to the OWASP Top 10, broken access control is considered one of the most critical security risks in modern applications [1].

Today's systems face many different types of attacks that specifically target access control. Some common examples include attackers trying to bypass authorization checks, stealing credentials, or gaining higher privileges than they should have. These types of vulnerabilities are dangerous because they allow attackers to act like legitimate users and access sensitive information. Research has shown that broken access control continues to be one of the most common and impactful vulnerabilities found in web applications, affecting a large number of systems [2].

Even though there are many security solutions available, a lot of systems still have weaknesses due to poor implementation or configuration issues. Problems like weak password policies, not using multi-factor authentication, and not properly enforcing user permissions are still very common. On top of that, user behavior, such as reusing passwords or choosing weak passwords, also makes these systems more vulnerable. As systems continue to grow and become more connected, it becomes harder to manage and secure access control effectively.

This paper looks at different types of vulnerabilities related to user accounts and access control systems and explains how they are commonly exploited. It also reviews different defense strategies that can be used to reduce these risks. The goal is to give a clear overview of the current security challenges and show where improvements are needed to better protect modern systems.

To better guide this study, the following research questions are considered:

- What are the most common vulnerabilities in user account and access control systems?
- How are these vulnerabilities typically exploited by attackers?
- What defense strategies are most effective in reducing these risks?

II. Research Methodologies

To complete this analysis, a structured literature review was used to gather information on access control vulnerabilities and defense strategies. Sources were collected from academic databases such as IEEE Xplore, Google Scholar, and ScienceDirect, since these provide access to reliable and peer-reviewed cybersecurity research. Search queries were created using key terms related to the topic, including "access control vulnerabilities," "authentication attacks," "authorization weaknesses," and "identity management security." These terms were combined in different ways to find relevant studies. Most

XXX-X-XXXX-XXXX-X/XX/$XX.00 ©20XX IEEE

of the sources used were published between 2009 and 2024 to make sure the information reflects current security challenges.

The selection process focused mainly on peer-reviewed journal articles, conference papers, and trusted industry sources such as OWASP. Sources that were outdated, not directly related to access control, or did not provide enough technical detail were excluded. In addition, duplicate sources were removed to keep the analysis more focused and relevant.

After collecting the sources, the information was reviewed and grouped based on common themes such as types of vulnerabilities, methods of exploitation, and defense strategies. This organization made it easier to compare findings across different studies and identify patterns and gaps in current access control security practices.

A. Research Gaps

Although access control and authentication systems have been widely studied, several gaps still exist in current research. One major gap is the lack of consistent implementation of security controls across different systems and environments. While many defense strategies such as multi-factor authentication and least privilege models are well understood, their effectiveness often depends on how they are applied in real-world scenarios. In addition, many studies focus on specific types of systems, such as web applications or cloud platforms, which makes it difficult to generalize findings across all environments.

Another gap is the limited research on user-related factors and how they impact access control security. Human behavior, such as weak password practices or improper use of permissions, continues to be a major cause of vulnerabilities, but it is not always addressed in technical solutions. There is also a need for more research on emerging security models, such as zero trust architecture, and how they can be consistently applied across different organizations. This shows that future research should not only focus on developing new security technologies, but also on improving how existing strategies are implemented and used by both systems and users.

B. Limitations of Study

This study is limited by the availability and scope of publicly accessible information. Most of the analysis is based on academic research papers, industry reports, and publicly documented vulnerabilities. As a result, some real-world vulnerabilities or organization-specific security implementations may not be fully represented. In addition, since access control systems vary widely between different platforms and technologies, it is not possible to cover every possible scenario in detail.

III. OVERVIEW OF USER ACCOUNT AND ACCESS CONTROL MECHANISMS

User account and access control mechanisms are used to manage how users interact with a system and what resources they are allowed to access. These systems help make sure that only authorized users can view or change sensitive information, which is important for keeping systems secure. Access control is a key part of cybersecurity because it helps prevent unauthorized access and can reduce the damage if a system is compromised.

There are two main components that make up access control systems: authentication and authorization. Authentication is the process of verifying a user's identity, usually through things like usernames and passwords, multi-factor authentication, or biometrics. Once a user is verified, authorization determines what actions that user is allowed to perform. For example, an administrator might have full access to a system, while a regular user may only be able to view certain data. Both authentication and authorization need to work together to properly enforce security.

Access control systems can be set up in different ways depending on the needs of an organization. One common approach is role-based access control (RBAC), where users are assigned roles and permissions are based on those roles. Another approach is attribute-based access control (ABAC), which looks at additional factors like user attributes, location, or time of access. These models help organizations manage access more efficiently, but if they are not configured correctly, they can create security vulnerabilities.

IV. CLASSIFICATION OF VULNERABILITIES

Vulnerabilities in user account and access control systems can occur at different stages of the authentication and authorization process. These weaknesses allow attackers to bypass security controls, gain unauthorized access, and potentially compromise sensitive data. Many of these vulnerabilities are caused by poor system design, misconfigurations, or weak security practices. To better understand these problems, vulnerabilities can be grouped into categories based on how they are exploited and which part of the access control system they affect.

A. Authentication Vulnerabilities

Authentication vulnerabilities occur when there are weaknesses in the process used to verify a user's identity. These weaknesses can allow attackers to gain access to accounts without proper authorization, often by exploiting poor password practices or flaws in authentication systems [3].

One of the most common types of authentication vulnerabilities involves weak password practices. Many users still rely on simple or reused passwords, which makes it easier for attackers to gain access through brute force or credential stuffing attacks. In a brute force attack, an attacker repeatedly

tries different password combinations until the correct one is found. Credential stuffing, on the other hand, uses leaked username and password combinations from previous data breaches to try and access other accounts where users may have reused the same credentials. These attacks are highly effective because they take advantage of common user behavior rather than complex technical flaws [4].

Another major issue is the lack of multi-factor authentication (MFA) in many systems. Without MFA, access to an account depends entirely on a single layer of security, usually a password. If that password is compromised, the attacker can gain full access without any additional verification. This significantly increases the risk of unauthorized access, especially in systems that store sensitive data [9]. Even though MFA is widely recommended as a basic security measure, it is still not consistently implemented across all platforms, leaving many systems exposed. Compared to brute force attacks, credential stuffing is more effective in modern systems because it relies on real leaked credentials rather than guessing, which significantly reduces detection and increases success rates. This highlights how user behavior, rather than system flaws alone, plays a major role in authentication security. Figure 1 shows how multi-factor authentication adds an additional layer of security beyond just a password, making it harder for attackers to gain unauthorized access.

Fig. 1. Example of multi-factor authentication adding an additional security layer [5].

Phishing attacks are another major source of authentication vulnerabilities and are often one of the most common ways attackers gain access to user accounts. In these attacks, users are tricked into providing their login credentials through fake websites or emails that appear legitimate. For example, an attacker may send an email that looks like it is from a trusted service and directs the user to a fake login page designed to capture their username and password. Unlike brute force or credential stuffing attacks, phishing relies on deceiving the user rather than directly attacking the system. This makes it especially dangerous because even well-designed authentication systems can be compromised if users are not able to recognize these types of threats.

B. Authorization Vulnerabilities

Authorization vulnerabilities occur when a system does not properly control what a user is allowed to do after they have logged in. Even if a user is successfully authenticated, they should only be able to access certain data or perform specific actions based on their role or permissions. When these controls are not enforced correctly, it can allow users to access restricted information or features they are not supposed to have. According to the OWASP Top 10, broken access control is considered one of the most critical security risks in modern applications [1], which shows how common and serious these types of issues still are today. In many cases, these vulnerabilities are not the result of complex system failures, but instead come from small mistakes in how permissions are designed or enforced. This makes them especially difficult to detect without proper testing and security reviews.

One of the most common examples of authorization vulnerabilities is insecure direct object reference (IDOR). This happens when an application allows users to access objects like files, records, or account data by simply changing an ID value in a request or URL. For example, a user might change a number in a web address and end up viewing another user's private information. This type of issue exists because the application does not properly check whether the user is authorized to access that specific resource. These vulnerabilities are dangerous because they are usually easy to exploit and do not require advanced skills. Research has shown that these kinds of access control weaknesses are still widely found in web applications and can lead to serious data exposure if not handled correctly [6]. Because of how simple these attacks are to perform, they are often overlooked during development and can remain in systems for long periods of time without being discovered.

Another important type of authorization issue is privilege escalation. This occurs when a user is able to gain higher-level permissions than they are supposed to have. For example, a regular user might find a way to access admin-level features due to weak role enforcement or misconfigured permissions. In some cases, attackers test different requests or hidden parts of an application to see what they can access. If the system does not properly verify permissions at every step, it can allow these actions to go through. Once an attacker gains elevated privileges, they can potentially modify data, access sensitive areas, or even take control of the system depending on how severe the issue is.

In many cases, authorization vulnerabilities come from small mistakes in how access control is implemented. Developers might assume that users will follow the normal process of using an application, but attackers often try to bypass those expected steps. If permission checks are only done on the front end and not the backend, it creates an opportunity for attackers to send

modified requests and perform actions they should not be allowed to do. This is why access control needs to be enforced consistently throughout the entire system and not just in certain parts of the application. While IDOR vulnerabilities are easier to exploit and require minimal technical skill, privilege escalation attacks tend to have a greater impact because they allow attackers to gain full system control. This distinction shows that not all access control vulnerabilities carry the same level of risk, even if they are equally common. Figure 2 shows an example of an insecure direct object reference (IDOR) vulnerability, where a user can access unauthorized data by modifying a request parameter.

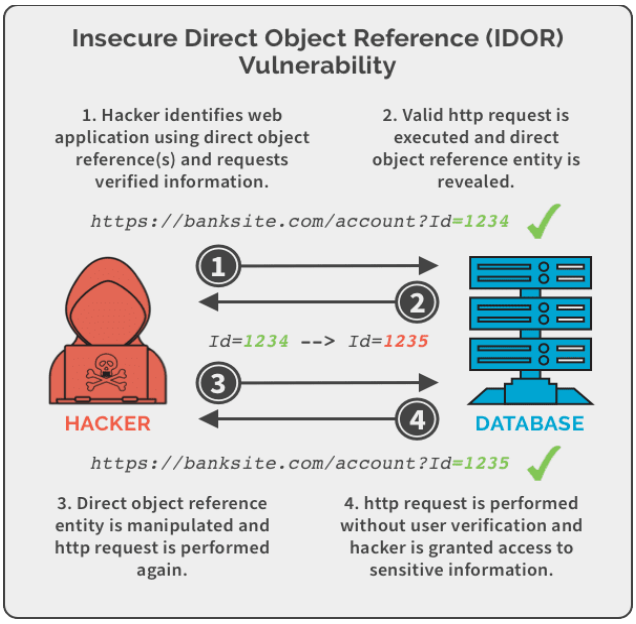

Fig. 2. Example of an insecure direct object reference (IDOR) vulnerability [7].

C. *Session and Identity Management Vulnerabilities*

Session and identity management vulnerabilities occur when systems do not properly handle how users are identified and tracked after logging in. Once a user is authenticated, the system typically creates a session to keep track of that user's activity without requiring them to log in again for every action. These sessions are usually managed through cookies or session tokens. If these mechanisms are not implemented securely, attackers can take advantage of them to impersonate legitimate users and gain unauthorized access to systems.

One of the most common session-related vulnerabilities is session hijacking. This happens when an attacker can steal or obtain a valid session token and use it to take over a user's active session. For example, if a user is connected to an unsecured public Wi-Fi network and their session cookie is not encrypted, an attacker could intercept that cookie and use it to access the user's account without needing their password. Research has shown that weak session management practices, such as transmitting session tokens over insecure connections or failing to properly protect them, can make these types of attacks much easier to carry out [8]. This is especially dangerous because the attacker doesn't even need to break the login process, since they are just reusing an already valid session. This highlights the importance of properly securing session tokens and ensuring they expire after a certain period of time to reduce the risk of unauthorized reuse.

Another related vulnerability is known as session fixation. During this type of attack, the attacker sets or predicts a session ID and tricks the user into logging in using that session. Once the user logs in, the attacker already knows the session ID and can use it to access the account. This can happen when applications do not generate a new session ID after a successful login, which is a common security mistake. Session fixation attacks show how important it is for systems to properly manage session creation and renewal, especially during authentication events.

Session expiration and improper session handling also create security risks. Some systems fail to automatically log users out after a period of inactivity, which leaves sessions open longer than necessary. If a user forgets to log out on a shared or public device, another person could easily access their account. Additionally, poorly configured cookies can make it easier for attackers to steal session information and use it to gain unauthorized access. These issues might seem small, but they can actually have a big impact on overall system security.

Together, these points show that session and identity management vulnerabilities highlight how important it is to protect not just the login process, but everything that happens after a user is authenticated. Even if strong authentication methods are in place, weak session handling can completely undermine those protections. This is why secure session management practices, such as encrypting session data, rotating session IDs, and enforcing proper timeouts, are critical for maintaining the security of modern applications. Among these vulnerabilities, session hijacking is often considered more severe than session fixation because it allows attackers to immediately take over an active session without requiring user interaction. This makes it particularly dangerous in environments where session tokens are not properly encrypted.

V. DEFENSE STRATEGIES

After looking at the different vulnerabilities in user account and access control systems, it is important to understand how these risks can be reduced. Many of the issues discussed in the previous section can be prevented by using stronger security practices and better system design. Instead of focusing on how attacks happen, this section shifts to how systems can be protected against them. There are multiple approaches that organizations use to improve security, but some methods are more widely used and effective than others. This section focuses on three main strategies: multi-factor authentication, the principle of least privilege, and zero trust architecture. Each

of these helps reduce the chances of unauthorized access and limits the impact if a system is compromised.

A. Multi-Factor Authentication (MFA)

Multi-factor authentication (MFA) is one of the most effective ways to protect user accounts from unauthorized access. Instead of relying only on a username and password, MFA requires the users to complete an extra step before logging in. This additional layer of security makes it much harder for attackers to access an account, even if they already have the correct password. As stated earlier, many of the authentication vulnerabilities come from weak or reused passwords, which makes systems easier targets for attacks like brute force or credential stuffing. Adding MFA helps reduce these risks by forcing attackers to get past more than just stolen credentials. This makes MFA important in modern systems where user credentials are frequently targeted by attackers.

MFA works by combining different types of authentication factors. These factors are usually grouped into three categories. Something the user knows, something the user has, and something the user is. A password is simply something the user knows, while a code sent to a phone or generated by an authentication app represents something the user has. Biometric methods, such as fingerprints or facial recognition fall into the category of something the user is. Using a combination of these factors adds more security because it requires more than one type of verification, which is much harder for an attacker to get past. This layered approach to authentication increases security by ensuring that a single compromised factor does not automatically result in full account access.

One major benefit of MFA is how it directly protects against many of the attacks discussed in the vulnerabilities section. For example, even if a password is exposed in a data breach an attacker would still need access to the second factor to successfully log in. This makes attacks like credential stuffing much less effective. Studies have shown that systems using MFA experience significantly less successful unauthorized login attempts compared to those that rely on only passwords [9]. This is why MFA is widely considered a basic and necessary security control for protecting user accounts.

MFA also helps reduce the overall impact if an account is targeted. Without this gaining access to an account can immediately give an attacker full control. With MFA in place, there is an extra barrier that can stop or slow down unauthorized access. In many cases the users are also notified when a login attempt occurs, which adds another layer of awareness and can help catch suspicious activity early. This makes MFA not only a preventive control, but also a useful tool for detecting potential threats as well.

Even though MFA is very effective, it is not completely bulletproof. Attackers can still try to bypass it using methods like phishing, where users are tricked into giving away verification codes. A poorly designed MFA system can also create weaknesses if they are not implemented correctly. Even with these limitations MFA is still one of the most practical and widely used security measures available today. When combined with other defense strategies, it plays a major role in protecting systems from many of the vulnerabilities discussed earlier. Figure 3 shows an example of how multi-factor authentication adds an extra layer of security by requiring a second form of verification during the login process.

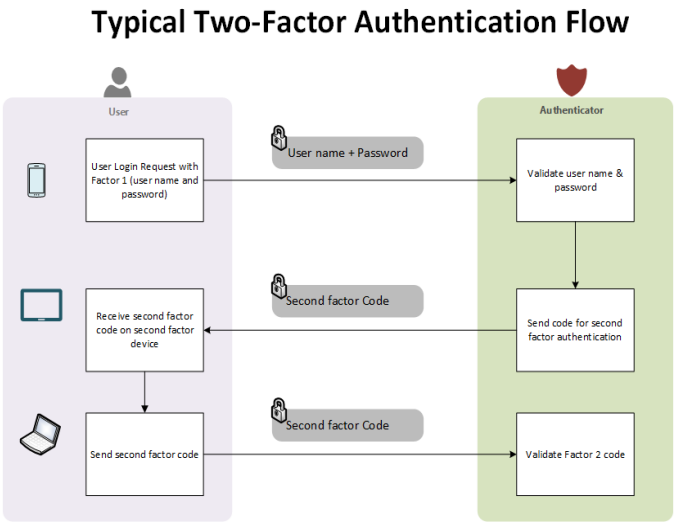

Fig. 3. Typical two-factor authentication flow [10].

B. Least Privilege Principle

The principal of least privilege is another important security concept that focuses on limiting what users and systems are allowed to access. Instead of giving users broad permissions, this approach makes sure that each user only has access to the specific resources they need to do their job. Limiting access in this way helps reduce unnecessary exposure and lowers the chances of misuse or unauthorized actions. This idea connects closely to many of the authorization issues discussed earlier, where users were able to access data or features that they should not have been allowed to use.

One of the main advantages of least privilege is that it helps reduce the risk of privilege escalation. In many attacks once an attacker gains access to a system, they try to increase their level of access to gain more control. If permissions are not properly restricted, even a low-level account could be used to reach sensitive areas of the system. When least privilege is enforced the attackers are limited to a smaller set of permissions, which makes it harder for them to move deeper into the system or cause serious damage [11].

Least privilege is often implemented using structured access control models like role-based access control (RBAC). In this setup, users are assigned roles based on their responsibilities,

and each role has a defined set of permissions. For example, a regular employee might only be able to view certain files, while an administrator has the ability to manage system settings. Keeping these roles clearly separated helps prevent users from accessing information outside of what they actually need. If roles are not clearly defined or maintained it can lead to the same types of access control problems that attackers take try to take advantage of.

Another benefit of this approach is that it helps reduce the impact of both mistakes and insider threats. Not all security issues come from outside attackers. Sometimes users accidentally access or change information they shouldn't, especially if they have more permissions than necessary. In other cases, someone inside an organization might misuse their access on purpose. Limiting permissions reduces these risks because users are only able to interact with a smaller portion of the system. It also becomes easier to track activity and notice anything unusual.

At the same time, applying least privilege in real systems is not always simple. Organizations need to carefully decide what level of access each user should have, and those needs can change over time. If permissions are too strict, it can slow down work or make systems harder to use. If they are too loose, security is weakened. Because of this, least privilege is not something that can be set once and forgotten. It requires ongoing updates, regular reviews, and adjustments as systems grow and change.

In general, the principle of least privilege is a practical and effective way to improve system security. By limiting access to only what is necessary, it reduces the chances of unauthorized actions and helps contain potential damage if an account is compromised. When combined with other strategies like multi-factor authentication, it plays an important role in protecting systems from many of the vulnerabilities discussed earlier.

C. Zero Trust Architecture

Zero Trust Architecture is a modern security approach that is based on the idea of "never trust, always verify." Instead of assuming that users or systems inside a network are automatically safe, Zero Trust treats every access request as potentially risky. This means that every user, device, and connection must be verified before being allowed to access resources even if they are already inside the network. This is different from traditional security models that focus mainly on protecting the perimeter of a network. In those older models, once a user gets inside, they are often trusted too much, this can create some serious security risks.

One of the main reasons Zero Trust has become more important is because of how modern systems are designed. Organizations now rely heavily on things like cloud services, remote work, and mobile devices, which makes it harder to clearly define a network boundary. Attackers can also gain access through things like stolen credentials or compromised devices, which allow them to move freely if there are not enough internal controls. Zero Trust helps address this problem by requiring continuous verification of identity and access, where every request is evaluated based on factors like user identity, device security, and location before access is granted [12]. This approach makes sure that access decisions are not based on a single login event but instead are continuously checked as conditions can change. Because of this even if an attacker gains access to valid credentials, they are less likely to maintain access for long without being detected or restricted.

Zero Trust also works closely with the principles discussed earlier such as least privilege and multi-factor authentication. For example, even if a user successfully logs in using MFA, Zero Trust still limits what they can access based on their role and continuously verifies their behavior. This prevents a situation where a single successful login gives too much access. In addition, Zero Trust enforces strict access controls so that users only interact with the resources they need, this aligns directly with the principle of least privilege. By combining these approaches organizations can build multiple layers of security instead of relying on just one method.

Another important part of Zero Trust is continuous monitoring. Instead of only checking a user at login, the system keeps evaluating activity throughout the session. If something unusual is detected such as a change in location or behavior, access can be restricted or removed. This helps reduce the risk of long-term unauthorized access, especially in cases where an attacker is using valid credentials. Continuous monitoring also makes it easier to detect suspicious activity earlier, which can prevent larger security incidents.

However, implementing Zero Trust can still be challenging. It requires organizations to rethink how access is managed and may involve updating systems, policies, and infrastructure. It can also take time to properly configure access controls and ensure that users are not negatively affected. If it is not implemented carefully, it could start usability issues or slow down workflows. Because of this many organizations will adopt Zero Trust gradually, starting with the most critical systems and expanding over time. In many cases, organizations also need to train users and adjust workflows, which can add to the complexity of adopting this model.

This highlights how Zero Trust Architecture provides a more secure way to manage access in modern environments. By requiring constant verification and limiting trust, it reduces the risk of unauthorized access and makes it harder for attackers to move around within a system. When combined with strategies like multi-factor authentication and least privilege, it then creates a stronger and more layered defense against many of the vulnerabilities talked about earlier. Figure 4 shows a basic example of how Zero Trust Architecture verifies users and devices before allowing access to system resources.

Fig. 4. Example of Zero Trust Architecture verifying user and device access [13].

D. Location-Based Access Control (LBAC)

Location-Based Access Control (LBAC) is another important security defense strategy that focuses on restricting access to systems and data based on a user's physical or network location. Instead of relying only on usernames and passwords, LBAC adds an extra layer of context by evaluating where a login request is coming from. Using location as part of the decision-making process allows organizations to have a better understanding of whether an access attempt is legitimate and helps reduce the chances of unauthorized users reaching sensitive systems.

One of the main ways LBAC improves security is by preventing access from suspicious or unexpected locations. For example, if a user account is normally accessed from within the United States and a login attempt suddenly comes from another country, the system can flag this as unusual behavior and block or challenge the request. Research has shown that incorporating contextual factors like location into authentication and access control decisions can significantly improve the detection of unauthorized access attempts [14]. In their study, Premarathne et al. emphasize that changes in user location play a critical role in finding potential security risks and that authentication systems should continuously evaluate location as part of the decision-making process. Even if an attacker has the correct username and password, LBAC adds another layer by recognizing that the login is coming from an abnormal or high-risk location.

LBAC is also effective in reducing the impact of broken access control vulnerabilities. In systems where users already have access to certain resources, restricting access based on location can help prevent misuse. For example, an organization might allow access to sensitive data only when a user is connected to an internal network or a trusted VPN. Even if an attacker gains access to a valid account, they will still need to be in an approved location to reach those resources. Limiting where access can occur makes it much harder for attackers to move freely within a system.

Another benefit of LBAC is its role in supporting risk-based and adaptive security models. Instead of applying the same level of security in every situation, systems can adjust their requirements depending on where a request is coming from. A login attempt from a trusted office location might require only basic authentication, while a login from an unknown or high-risk location could trigger more verification steps such as multi-factor authentication. This aligns with the findings of Premarathne et al., who highlight the importance of continuously evaluating contextual changes, such as location, to improve the reliability of authentication decisions in dynamic environments. This makes LBAC a flexible approach that is especially useful in environments where users frequently access systems from different locations or devices.

LBAC also works well when combined with other security strategies discussed in this paper, such as multi-factor authentication, least privilege, and Zero Trust Architecture. In a Zero Trust model, location is only one of the factors used to evaluate access requests. Rather than automatically trusting users based on network position, the system continuously checks whether a request meets specific conditions, including location. When combined with least privilege, LBAC ensures that users not only have limited access, but can only use that access from approved environments. This layered approach makes it much harder for attackers to take advantage of a single weakness.

At the same time, LBAC does have some limitations that organizations need to consider. Location data is not always perfectly correct, and attackers may try to bypass restrictions using tools like VPNs or proxy servers. Because of this, LBAC should not be used on its own, but instead as part of a broader security strategy. When combined with strong authentication methods and continuous monitoring, it becomes much more effective at detecting and preventing suspicious activity. In addition, location data can sometimes be inaccurate or affected by factors such as mobile networks or shared IP addresses, which can lead to false positives or unnecessary access restrictions. This means organizations need to carefully balance security with usability when implementing LBAC.

Pulling all these defense strategies together, LBAC plays a key role in strengthening overall system security. It adds another layer of protection by considering where access requests are coming from, which helps organizations spot unusual behavior and reduce the risk of unauthorized access. When combined with strategies like MFA, least privilege, and Zero Trust, LBAC helps create a more complete and effective defense against many of the vulnerabilities discussed earlier in this paper.

VI. RESULTS AND FINDINGS

The research in this paper shows that access control vulnerabilities, mainly broken access control and weak authentication, have continued to be some of the most common and serious security issues in modern systems. Sources such as OWASP highlight that these vulnerabilities are consistently ranked among the top risks because they allow attackers to bypass restrictions and act as legitimate users [1]. In many cases these systems rely too heavily on basic authentication methods like passwords, which creates a single point of failure if those credentials are compromised. The research also shows that these issues are not always caused by complex attacks, but instead often caused by simple misconfigurations or poor implementation of access controls. This makes them especially dangerous because they can exist in systems without being noticed for long periods of time.

When comparing different defense strategies, it becomes clear that no single solution is enough to fully protect against these types of vulnerabilities. Multi-factor authentication helps reduce the risk of stolen credentials being used, but it does not completely stop attackers if other weaknesses exist in the system [9]. The principle of least privilege limits what users can access, which helps reduce the overall impact of a breach [11]. More advanced approaches like Zero Trust Architecture go further by requiring continuous verification instead of assuming trust based on network location [12]. In addition, research shows that incorporating contextual factors like location into access decisions can also improve the detection of suspicious activity and prevent unauthorized access attempts [14]. Each of these strategies addresses a different part of the problem, which shows that combining them is more effective than relying on just one.

Another key finding is that modern security approaches are moving toward layered and adaptive defense models rather than static ones. Instead of applying the same level of security in every situation these systems are starting to adjust based on factors like user behavior, location, and risk level. This shift reflects the idea that attackers are constantly changing their methods so defenses also need to be flexible. Each strategy still has its own limitations. For example, location-based controls can sometimes be bypassed, and even strong authentication methods can fail if not properly implemented. The research suggests that the most effective approach is to combine multiple strategies, such as MFA, least privilege, Zero Trust, and contextual controls, to create a stronger and more reliable defense against the vulnerabilities Covered in this paper.

One additional point that stands out from the research is how important consistency is when applying these security strategies. Even when organizations adopt these strong approaches like Zero Trust or multi-factor authentication, gaps can still appear if policies are not enforced consistently across all systems. In many cases the attackers take advantage of these inconsistencies rather than directly breaking through strong defenses. This shows that security is not only about choosing the right strategies, but also about making sure they are applied in a consistent and controlled way across the entire environment.

DISCUSSION AND CONCLUSION

Access control and authentication weaknesses continue to be a major issue in modern systems, mainly because they are often overlooked or not fully implemented. Vulnerabilities like broken access control and weak authentication allow attackers to bypass security measures and gain unauthorized access with relatively simple methods. These risks are especially significant because they often result from common design and configuration mistakes rather than advanced attacks. Improving access control requires not just adding new security measures but understanding how these weaknesses are exploited and addressing them more effectively.

At the same time, the research also shows that even strong defense strategies have limitations. Multi-factor authentication helps protect against stolen credentials, but it cannot stop every type of attack. Least privilege reduces the amount of damage an attacker can cause, but it depends heavily on proper implementation. More advanced approaches like Zero Trust and location-based access control improve security by adding continuous verification and context, but they can still be bypassed if not combined with other controls. Because of this, one of the most important takeaways is that security should be built in layers rather than relying on a single method. Combining multiple strategies and adapting to different situations provides a more effective way to reduce risk and protect systems from the types of vulnerabilities discussed in this paper.

ACKNOWLEDGMENT

We would like to thank our professor, Naresh Adhikari, for his guidance and for the resources and documentation that supported this research.

LIST OF ACRONYMS

RBAC	role-based access control
ABAC	attribute-based access control
MFA	multi-factor authentication
IDOR	insecure direct object reference
LBAC	location-based access control
VPN	virtual private network

CONTRIBUTION

Tyson Lamb - Contributed to both the research and writing of the paper, mainly focusing on the research methodologies and vulnerability analysis sections. Also helped organize sources, check how vulnerabilities were classified, and make sure everything connected back to the research questions.

Christopher Shuler - Contributed to research and writing, with a focus on the defense strategies, results, and discussion sections. Also worked on connecting ideas across sections and explaining how different security strategies help reduce risk in real-world systems.

REFERENCES

[1] OWASP Foundation, "A01:2021 Broken Access Control," OWASP Top 10, 2021. [Online]. Available: https://owasp.org/Top10/A01_2021-Broken_Access_Control/. [Accessed: Apr. 20, 2026].

[2] A. Anas, S. Elgamal, and B. Youssef, "Survey on detecting and preventing web application broken access control attacks," International Journal of Electrical and Computer Engineering (IJECE), vol. 14, no. 1, pp. 772–781, 2024. [Online]. Available: https://ijece.iaescore.com/index.php/IJECE/article/view/33835/17135. [Accessed: Apr. 21, 2026].

[3] M. Dalton, C. Kozyrakis, and N. Zeldovich, "Nemesis: Preventing authentication & access control vulnerabilities in web applications," in Proc. 18th USENIX Security Symposium, 2009. [Online]. Available: https://www.usenix.org/legacy/event/sec09/tech/full_papers/dalton.pdf. [Accessed: Apr. 21, 2026].

[4] K. Thomas, D. Yuxing, K. Bursztein, C. Grier, N. Paxson, and D. Boneh, "Protecting accounts from credential stuffing with password breach alerting," in Proc. 28th USENIX Security Symposium (USENIX Security 21), 2019. [Online]. Available: https://www.usenix.org/system/files/sec19-thomas.pdf. [Accessed: Apr. 21, 2026].

[5] B. Martin, "What is Multifactor Authentication (MFA)?," Teknologize, Sep. 29, 2020. [Online]. Available: https://blog.teknologize.com/what-is-multifactor-authentication. [Accessed: Apr. 21, 2026].

[6] S. Jan, S. U. Khan, A. Wahab, and Dr. Mohammad, "Access Restricted: A Study of Broken Access Control Vulnerabilities," Archives of Advanced Engineering Science, 2025. [Online]. Available: https://ojs.bonviewpress.com/index.php/AAES/article/view/4016/1315. [Accessed: Apr. 22, 2026].

[7] S. Oza, "Insecure Direct Object Reference (IDOR) - Web-based Application Security, Part 6," Spanning, Feb. 20, 2020. [Online]. Available: https://www.spanning.com/blog/insecure-direct-object-reference-web-based-application-security-part-6/. [Accessed: Apr. 22, 2026].

[8] I. Dacosta, S. Chakradeo, M. Ahamad, and P. Traynor, "One-time cookies: Preventing session hijacking attacks with stateless authentication tokens," in Proc. 21st USENIX Security Symposium, 2012. [Online]. Available: https://dl.acm.org/doi/epdf/10.1145/2220352.2220353. [Accessed: Apr. 23, 2026].

[9] I. E. Akpan, "Evaluating the effectiveness of multi-factor authentication in preventing unauthorized access to university information systems," International Journal of Computer Science and Mathematical Theory, 2026. [Online]. Available: https://www.researchgate.net/profile/Idongesit-Akpan-6/publication/400818822_Evaluating_the_Effectiveness_of_Multi-Factor_Authentication_in_Preventing_Unauthorized_Access_to_University_Information_Systems. [Accessed: Apr. 23, 2026].

[10] M. N. A. Khan, "Two-factor authentication with Azure," Dec. 2018. [Online]. Available: https://mnabeelkhan.blogspot.com/2018/12/two-factor-authentication-with-azure.html. [Accessed: Apr. 23, 2026].

[11] S. A. Ebad and M. Amara, "The principle of least privilege in microservices: A systematic mapping study," Applied Sciences, vol. 16, no. 3, p. 1495, 2026. [Online]. Available: https://www.mdpi.com/2076-3417/16/3/1495. [Accessed: Apr. 23, 2026].

[12] National Institute of Standards and Technology, "Zero Trust Architecture," NIST Special Publication 800-207, Aug. 2020. [Online]. Available: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf. [Accessed: Apr. 23, 2026].

[13] E. Ekirigwe, "Zero trust architecture in practice: Real-world implementation steps," Dev.to, [Online]. Available: https://dev.to/ekirigwe/zero-trust-architecture-in-practice-real-world-implementation-steps-ih. [Accessed: Apr. 23, 2026].

[14] U. S. Premarathne, I. Khalil, and M. Atiquzzaman, "Location-dependent disclosure risk based decision support framework for persistent authentication in pervasive computing applications," Computer Networks, vol. 88, pp. 161-177, 2015. [Online]. Available: https://www.sciencedirect.com/science/article/pii/S1389128615001954. [Accessed: Apr. 27, 2026].